

Applied Security-Informed Safety Case Studies

Dr Ayman El Hajjar

CyBOK © Crown Copyright, The National Cyber Security Centre 2026, licensed under the Open Government Licence

<http://www.nationalarchives.gov.uk/doc/open-government-licence/>

The lecture maps to the following CyBOK Knowledge Areas:

Full Coverage:

- Infrastructure Security → Cyber-Physical Systems Security
- Infrastructure Security → Network Security
- Human, Organisational and Regulatory Aspects → Risk Management & Governance

Partly Covered:

- Infrastructure Security → Physical Layer and Telecommunications Security
- Attacks and Defences → Security Operations & Incident Management
- Systems Security → Authentication, Authorisation & Accountability

APPLYING SECURITY-INFORMED SAFETY

MEDICAL IOT CASE STUDY

SMART BUILDING CASE STUDY

LOW-POWER WIRELESS CASE STUDY

COMPARING THE APPLIED CASES

CROSS-CASE SECURITY-INFORMED SAFETY PATTERNS

Applying Security-Informed Safety

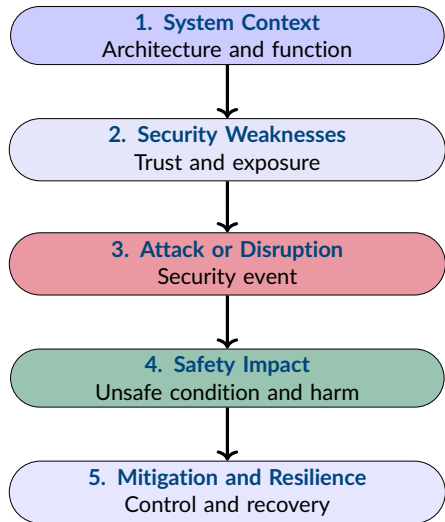
Applied Security-Informed Safety

Uses **security analysis**, **hazard reasoning**, and **safety consequences** together to examine how attacks and disruptions affect real system behaviour.

- Previous lectures introduced security failures, hazards, assurance, wireless threats, safety-critical IoT, and resilience.
- Applied cases bring these concepts together within a **complete system context**.
- The focus is not only on whether an attack succeeds.
- The analysis traces how a security event changes **data**, **communication**, **system behaviour**, and possible **safety outcomes**.

The same security event can have very different safety consequences depending on the system in which it occurs.

A COMMON CASE STUDY ANALYSIS METHOD



- Each case uses the **same analysis sequence**.
- This supports comparison across technologies and operational environments.
- The objective is to identify how security weaknesses create or amplify **safety-relevant behaviour**.

A case study should connect technical evidence to operational effects, unsafe conditions and appropriate controls.

THREE CATEGORIES OF ATTACK AND DISRUPTION

Infrastructure Attacks and Disruptions

Affect supporting components, services, gateways, access points, brokers, or network availability.

Communication and Protocol Attacks

Exploit wireless links, protocol behaviour, message exchange, association, pairing, or transport mechanisms.

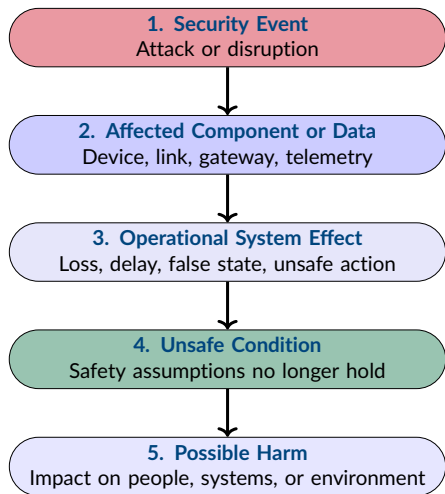
Telemetry and Application-Layer Attacks

Manipulate sensor values, application messages, commands, state, or the interpretation of system data.

- An attack may fall into **more than one category**.
- The category identifies where the security event occurs, not the final safety consequence.
- Safety analysis must trace how the event affects **system behaviour**.

The same safety hazard may be reached through attacks at different layers of the system.

TRACING SECURITY EVENTS TO SAFETY HARM



- The **security event** identifies what happened technically.
- The **operational effect** explains how the system changes as a result.
- The **unsafe condition** identifies where expected safety assumptions are violated.
- Possible harm should be linked to the system context rather than assumed from the attack alone.

Security-informed safety asks how a technical event propagates through system behaviour before harm becomes possible.

Medical IoT Case Study

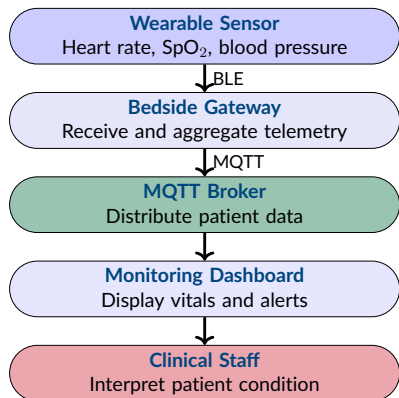
Case Study Context

A simulated patient monitoring system uses wearable sensors, a gateway, MQTT communication and a central dashboard to provide **continuous visibility of patient vital signs**.

- Continuous monitoring supports **early recognition of deterioration**.
- Staff may act on alerts without directly observing the patient.
- Delayed or false readings can change the perceived **clinical state**.
- Missing data may leave deterioration **unrecognised**.
- Patient safety therefore depends on **trustworthy monitoring**.

When patient monitoring data becomes false, delayed, or unavailable, the clinical picture may no longer reflect the patient's actual condition.

MEDICAL IOT SYSTEM ARCHITECTURE



- Patient data moves through **multiple dependent components** before it reaches clinical staff.
- Each stage introduces assumptions about **identity, message integrity, availability** and **data validity**.
- Failure or compromise at an earlier stage may propagate to the monitoring dashboard.
- The dashboard provides a **clinical representation** of the patient, not direct observation of the patient.

The clinical decision may be correct for the data displayed while still being unsafe if the underlying telemetry is untrustworthy.

SECURITY WEAKNESSES IN THE MEDICAL IOT SYSTEM

- The wearable and gateway use **weak trust assumptions** when exchanging patient telemetry.
- MQTT communication may operate without **authentication** or **encryption**.
- The gateway accepts incoming readings without sufficient **input validation** or **physiological plausibility checks**.
- The dashboard trusts received telemetry as the current representation of the patient's condition.
- A small number of shared components, including the gateway and broker, create **single points of failure**.

The main weakness is not only that data can be attacked, but that downstream components may continue to trust it.

INFRASTRUCTURE ATTACKS AND DISRUPTIONS

- **Access point disruption** can disconnect gateways or monitoring components from the wireless network.
- **Gateway failure or compromise** may interrupt telemetry from one or more wearable devices.
- **MQTT broker unavailability** can prevent patient data from reaching the monitoring dashboard.
- **Wireless interference or denial of service** may create intermittent or prolonged loss of communication.
- Shared infrastructure can allow a single disruption to affect **multiple patients simultaneously**.

Infrastructure failure may create a loss of clinical visibility even when the wearable sensors continue operating correctly.

COMMUNICATION AND PROTOCOL ATTACKS

- **Weak BLE pairing** may allow unauthorised devices to observe or imitate wearable communication.
- **Eavesdropping** can expose patient telemetry when communication is not adequately protected.
- **Spoofing** may allow an attacker to impersonate a wearable device or trusted data source.
- **Replay attacks** can resend previously valid vital-sign readings as if they were current.
- **Unauthorised MQTT publish or subscribe operations** can expose or manipulate patient data.

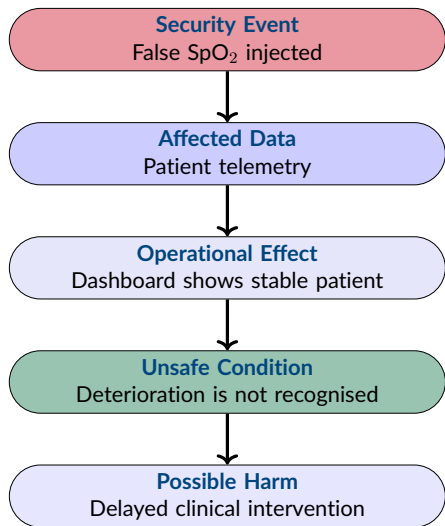
A message may be correctly formatted and accepted by the protocol while still being unauthorised, stale, or malicious.

TELEMETRY AND APPLICATION-LAYER ATTACKS

- **False vital-sign injection** changes the clinical state presented to monitoring staff.
- **Telemetry suppression** prevents current readings from reaching the dashboard.
- **Silent corruption** can make a deteriorating patient appear stable.
- **Impossible physiological values** may be accepted when the gateway performs no plausibility checking.
- **Stale telemetry** may remain visible without clearly indicating that the data is no longer current.

False reassurance can be more dangerous than obvious data loss because staff may continue to trust the displayed clinical state.

MEDICAL IOT SECURITY-TO-SAFETY ESCALATION



- The attack does not directly harm the patient.
- Harm becomes possible because compromised telemetry changes the **clinical representation** used for decision-making.
- The safety consequence depends on the patient's real condition, staff response and available alternative observations.

The critical escalation occurs when untrusted telemetry is allowed to influence a safety-relevant clinical decision.

MITIGATION AND RESILIENCE FOR MEDICAL IOT

- **Authenticate devices and gateways** before accepting patient telemetry.
- Protect communication using **encryption**, **message integrity** and **replay protection**.
- Apply **physiological plausibility checks** and identify impossible or rapidly changing values.
- Detect **missing and stale telemetry** rather than continuing to display old readings as current.
- Use **local alarms**, alternative observations and defined degraded operation when remote monitoring becomes untrustworthy.
- Preserve logs and communication evidence for **incident investigation** and assurance review.

A resilient monitoring system should make loss of trust visible and move staff towards safer alternative observation rather than silently continuing.

Smart Building Case Study

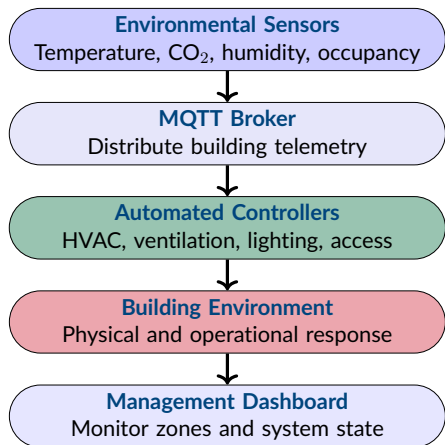
Case Study Context

A simulated building management system uses environmental monitoring and automated control to maintain **safe and acceptable conditions across multiple zones**.

- Building services may respond **automatically** to changing conditions.
- Occupants may depend on ventilation, lighting and access systems working correctly.
- False environmental data can create an incorrect **building state**.
- Delayed or missing telemetry can prevent timely response to change.
- Safe automation therefore depends on **trustworthy environmental awareness**.

When automated controllers trust incorrect sensor data, a telemetry failure can become an incorrect physical or operational response.

SMART BUILDING SYSTEM ARCHITECTURE



- Sensor telemetry is used by both **automated controllers** and the management dashboard.
- Controllers respond to data without requiring human approval during normal operation.
- A compromised sensor value can therefore influence **system state** and **physical behaviour**.
- Centralised MQTT communication creates dependencies between otherwise separate building zones.

Automation reduces response time, but also reduces the opportunity for a human to detect untrustworthy data before the system acts.

SECURITY WEAKNESSES IN THE SMART BUILDING SYSTEM

- The MQTT broker may accept connections without **authentication**.
- Sensor telemetry is transmitted without sufficient **message integrity protection**.
- Automated controllers accept values without **sanity checking** or **physical plausibility validation**.
- Multiple zones share the same broker without strong **per-zone isolation**.
- Controllers respond directly to sensor data and may amplify a false reading into an automated action.
- The broker and central communication path create **shared dependencies** across the building.

The system assumes that validly delivered telemetry is also trustworthy and physically meaningful.

INFRASTRUCTURE ATTACKS AND DISRUPTIONS

- **Access point disruption** can disconnect sensors or controllers from the building network.
- **MQTT broker failure** may interrupt telemetry and automated control across several zones.
- **Gateway or network disruption** can create partial loss of visibility or control.
- **Wireless interference or denial of service** may delay environmental updates.
- Shared infrastructure allows one failure to create a **multi-zone operational impact**.

A central infrastructure failure can turn several independent building zones into one shared failure domain.

- **Unauthorised MQTT publishing** can inject messages into trusted building topics.
- **Unauthorised subscription** may expose environmental and occupancy information.
- **Replay attacks** can present old sensor states as current conditions.
- **Message flooding** may delay legitimate telemetry or overload broker resources.
- Weak topic-level access control may allow a compromised device to affect **other zones or services**.

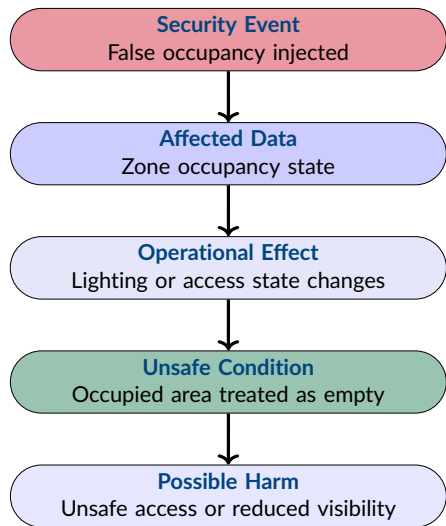
MQTT topic structure organises messages, but does not by itself establish whether a publisher is authorised or trustworthy.

TELEMETRY AND APPLICATION-LAYER ATTACKS

- **False temperature injection** can trigger unnecessary heating or cooling.
- **False CO₂ readings** can cause incorrect ventilation behaviour.
- **Occupancy spoofing** may influence lighting and access-control decisions.
- **Coordinated false telemetry** can activate several controllers simultaneously.
- **Rapidly changing values** may cause controllers to oscillate between operational states.
- Invalid values may still be processed when application logic lacks **plausibility checks**.

In automated environments, manipulated telemetry can become a control input without the attacker directly accessing the controller.

SMART BUILDING SECURITY-TO-SAFETY ESCALATION



- The manipulated message changes the system's **representation of occupancy**.
- Automated controllers then act consistently with the false state.
- The resulting unsafe condition depends on the real occupancy and operational context.

The controller may operate exactly as designed while still producing an unsafe outcome because its trusted input is false.

MITIGATION AND RESILIENCE FOR SMART BUILDINGS

- Apply **device authentication** and topic-level access control to MQTT communication.
- Protect telemetry using **encryption**, **integrity protection** and **replay controls**.
- Validate sensor values against **physical ranges**, expected rates of change and related measurements.
- Use **segmentation** to prevent a compromised zone affecting unrelated zones.
- Apply **rate limiting** and safeguards to reduce rapid or cascading state changes.
- Define **local fallback** and degraded operation when shared communication infrastructure becomes unavailable.
- Monitor disagreement between telemetry and controller behaviour as **safety-relevant evidence**.

A resilient building system should constrain automated behaviour when the environmental state is uncertain or untrustworthy.

Low-Power Wireless Case Study

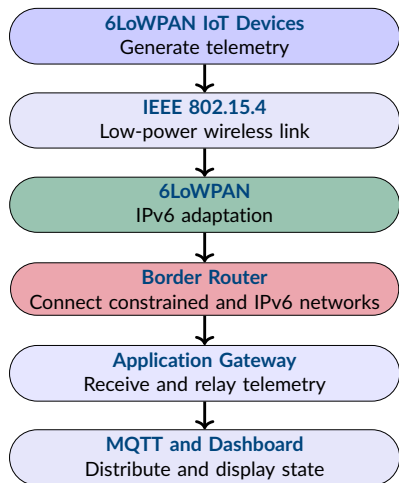
Case Study Context

A simulated 6LoWPAN system provides **low-power telemetry** from constrained wireless devices.

- Low-power devices monitor **physical or operational conditions**.
- Communication may be **constrained**, intermittent or delayed.
- Missing or false telemetry can reduce **operational awareness**.
- Safe operation depends on **timely and trustworthy telemetry**.

Incorrect, delayed, or unavailable telemetry may prevent an unsafe condition from being recognised.

LOW-POWER WIRELESS SYSTEM ARCHITECTURE



- The telemetry path crosses **several protocol and trust boundaries**.
- The border router is both a **network boundary** and a potential **single point of failure**.
- The application gateway operates on telemetry after network forwarding has occurred.
- Security applied only at the MQTT stage does not protect the complete communication path.

Trust in the dashboard depends on every stage that carries, forwards, interprets, or republishes the telemetry.

SECURITY WEAKNESSES IN LOW-POWER WIRELESS SYSTEMS

- Constrained devices may have limited **processing**, **memory** and **energy** available for security controls.
- Wireless communication is exposed to **interference**, disruption and observation.
- The border router creates a critical **trust and availability boundary**.
- UDP telemetry may lack sufficient **authentication**, **freshness** or **replay protection**.
- The application gateway may accept telemetry without verifying source identity or operational plausibility.
- The dashboard may treat the most recently received value as a trustworthy representation of current system state.

Constrained communication does not remove the need for security controls, but it can make their design and deployment more difficult.

INFRASTRUCTURE ATTACKS AND DISRUPTIONS

- **IEEE 802.15.4 disruption** can prevent constrained devices from delivering telemetry.
- **6LoWPAN network disruption** may result in missing packets or loss of one or more nodes.
- **Border-router failure** can disconnect several sensor streams from the wider IPv6 environment.
- **Forwarding-path disruption** may interrupt delivery even when the source devices continue transmitting.
- **Application-gateway or MQTT-relay failure** can stop telemetry from reaching conventional monitoring services.
- Shared infrastructure can create a **common failure domain** for several constrained devices.

Several healthy sensors may become operationally invisible when a shared border router or forwarding component fails.

COMMUNICATION AND PROTOCOL ATTACKS

- **Packet loss or delivery disruption** can create incomplete or intermittent telemetry.
- **UDP telemetry spoofing** may introduce messages from an unauthorised or false source.
- **Replay attacks** can present previously valid sensor readings as current.
- **Delayed delivery** can make telemetry operationally obsolete before it reaches the monitoring system.
- **MQTT message injection** may alter telemetry after it has crossed the constrained network.
- Attacks at different protocol layers may produce a similar visible effect at the dashboard.

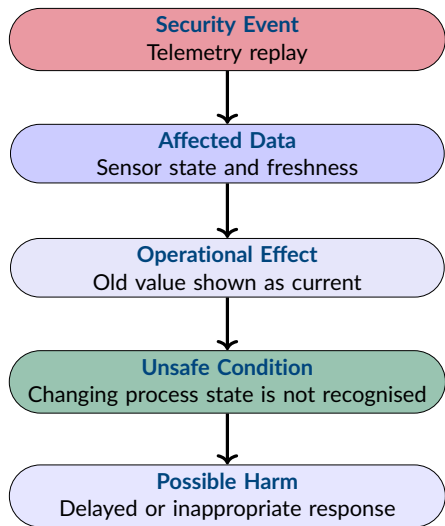
A missing dashboard update does not identify whether the failure occurred at IEEE 802.15.4, 6LoWPAN, IPv6, UDP, the relay, or MQTT.

TELEMETRY AND APPLICATION-LAYER ATTACKS

- **Spoofed telemetry** can create a false representation of a monitored condition.
- **Extreme or implausible values** may trigger an inappropriate operational response.
- **Stale telemetry** can leave old system state visible without an effective freshness warning.
- **Telemetry suppression** may hide a developing unsafe condition.
- **Conflicting sensor values** can reduce confidence in the monitored state.
- Application services may continue processing values without checking expected **ranges**, **rates of change**, or **source identity**.

False telemetry may preserve the appearance of normal operation while reducing the opportunity for timely intervention.

LOW-POWER WIRELESS SECURITY-TO-SAFETY ESCALATION



- The replayed message was once **valid**, but is no longer current.
- The monitoring system fails to distinguish historical telemetry from the current physical state.
- The unsafe condition develops because the real process changes while the displayed state remains unchanged.

In time-sensitive monitoring, freshness is part of data trust and can have direct safety relevance.

MITIGATION AND RESILIENCE FOR LOW-POWER WIRELESS

- Protect constrained telemetry using appropriate **device and message authentication**.
- Apply **freshness checks**, sequence controls, or other replay protection.
- Monitor **missing**, **delayed** and **intermittent** telemetry as distinct operational conditions.
- Validate sensor values against expected **physical ranges** and rates of change.
- Reduce dependence on a single border router through appropriate **fallback** or alternative communication paths.
- Apply controls at the **constrained network**, **border router**, **application gateway** and **MQTT** layers.
- Use degraded operation or human review when the current physical state can no longer be established confidently.

Resilience requires the monitoring system to recognise when telemetry is no longer sufficiently trustworthy or timely for safe decisions.

Comparing the Applied Cases

COMPARING THE THREE APPLIED CASES

Case	Critical Dependency		Security Failure		Safety-Relevant Effect	
Medical IoT	Trusted	patient	False, stale, or missing		Incorrect	clinical
	telemetry		vitals		representation	
Smart Building	Trusted		Manipulated	or	Incorrect	automated
	environmental state		unavailable	sensor	response	
			data			
Low-Power Wireless	Timely	constrained	Replay, delay, spoofing,		Loss of	operational
	telemetry		or loss		awareness	

- The technologies differ, but each system depends on **trustworthy telemetry**.
- Security failures become safety-relevant when data influences **decisions**, **automation**, or **operational awareness**.

The common issue is not the protocol alone. It is how much system behaviour depends on data that may no longer be trustworthy.

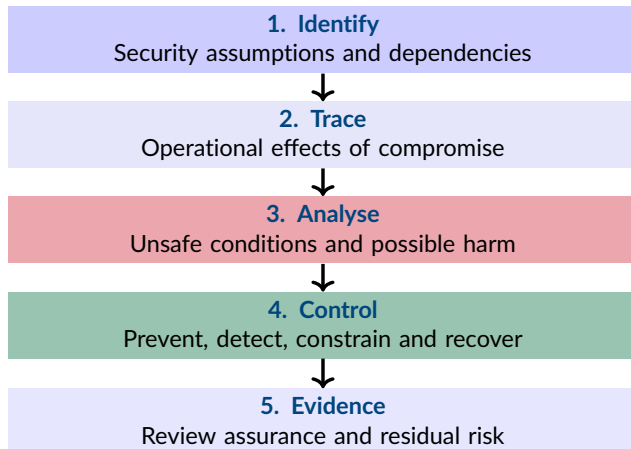
COMMON SECURITY-INFORMED SAFETY PATTERNS

- **Telemetry trust** is a safety dependency across all three systems.
- **Automation amplifies errors** by converting false data into operational action.
- **Availability failures** can remove visibility before an unsafe condition is recognised.
- **Shared infrastructure** creates single points and common modes of failure.
- **Detection alone is insufficient** without a defined safe response.
- **Graceful degradation** is needed when current system state can no longer be trusted.

Different systems and protocols can exhibit the same security-to-safety escalation pattern.

Cross-Case Security-Informed Safety Patterns

APPLYING SECURITY-INFORMED SAFETY IN PRACTICE



Security-informed safety connects technical security events to system behaviour, safety consequences, controls and assurance evidence.

- Applied Security-Informed Safety traces **security events** through system behaviour to **unsafe conditions** and possible harm.
- Infrastructure, communication and protocol, and telemetry or application-layer attacks can reach the **same safety-relevant outcome** through different paths.
- In Medical IoT, untrustworthy telemetry can create an **incorrect clinical representation**.
- In Smart Buildings, false environmental data can trigger **incorrect automated behaviour**.
- In low-power wireless systems, loss, delay, spoofing, or replay can create a **loss of operational awareness**.
- Across all three cases, **telemetry trust**, shared infrastructure, automation and timely detection are critical safety dependencies.
- Mitigation must combine prevention, validation, monitoring, **graceful degradation**, recovery and assurance evidence.

KEY REFERENCES

- NIST. (2021). *Developing Cyber-Resilient Systems: A Systems Security Engineering Approach*. NIST SP 800-160 Vol. 2 Rev. 1. [\[Link\]](#)
- FDA. *Cybersecurity in Medical Devices*. [\[Link\]](#)
- NCSC. *Operational Technology Guidance*. [\[Link\]](#)
- OASIS. *MQTT Version 5.0*. [\[Link\]](#)
- IETF. *IPv6 over Low-Power Wireless Personal Area Networks*. [\[Link\]](#)